

Consent Capture & Audit

Parent: INFOSEC_POLICY.md, PRIVACY_POLICY.md **Owner:** Matt Fellows — matt@tangiblevalue.com
Effective date: 2026-05-06 **Review cadence:** annually, or any time the data collection or processors change.

1. Purpose

This document describes how the application obtains, records, and can demonstrate consent from a user before collecting, processing, or storing data on their behalf.

The relevant data collection point is the **Plaid Link** flow: the moment a user authorizes the application to retrieve and store financial data from an institution through Plaid. Before that flow can start, the user must take an explicit action that is logged.

2. Three-layer consent model

Layer	What	Where
Notice	The user can read the full privacy policy before consenting.	Public route at /privacy; footer link on every authenticated page (Layout.tsx).
Affirmative action	The user (a) checks an explicit acknowledgement checkbox and (b) clicks the “Connect Bank Account” button. The button is disabled until the checkbox is checked.	src/components/PlaidLink.tsx.
Auditability	A row is written to the consents Firestore collection at the moment the user initiates Plaid Link, capturing user ID, timestamp, privacy-policy version active at the time, and the exact consent text shown.	POST /api/plaid/consent → consents collection.

This matches Plaid’s expectation that the app provide its own consent layer in addition to the Plaid Link consent screens that Plaid itself surfaces during the institution-login flow.

3. Consent text

The exact text shown to the user, which they must affirmatively acknowledge before Plaid Link opens:

By connecting an account, you authorize wealth-navigator to retrieve and store transaction history, account balances, holdings, and (where applicable) liability details from this financial institution via Plaid, for the purpose of personal financial tracking. You can revoke this authorization at any time by disconnecting the account from the application, which will revoke the Plaid access token and remove stored institution data. See the Privacy Policy for full details on what is collected, how long it is retained, and how to request deletion.

The acknowledgement checkbox label:

I have read and agree to the Privacy Policy.

If this text materially changes, the **Privacy Policy version** in PRIVACY_POLICY.md must be incremented in the same change. The `privacy_policy_version` field on each consent record is what links a consent event back to the exact text the user agreed to.

4. Data captured per consent event

Each row in the consents Firestore collection contains:

Field	Source	Notes
<code>user_id</code>	Authenticated session (<code>req.user.id</code>)	Tied to the active user.
<code>type</code>	Constant: <code>plaid_link_initiated</code>	Future-proofs the schema for other consent types.
<code>privacy_policy_version</code>	Hardcoded constant in the request body, e.g. "1.0"	Must match the Version field at top of PRIVACY_POLICY.md.
<code>consent_text_sha256</code>	SHA-256 of the displayed consent text	Defends against later disputes about what was shown.
<code>consented_at</code>	Server-side ISO timestamp	Authoritative time.
<code>user_agent</code>	User-Agent request header	For audit / dispute resolution.
<code>app_version (optional)</code>	Build ID or git SHA	Helps tie back to the deployed UI at the time of consent.

We deliberately do **not** store IP addresses. Vercel's edge proxies make IP capture unreliable, and IPs are personal data with little forensic value at this scale.

5. Withdrawal of consent

A user can withdraw consent at any time by disconnecting the institution within the app:

- The user clicks "Disconnect" on the institution row.
- The app calls `DELETE /api/plaid/accounts/:itemId`, which:
 - Calls `plaidService.removeItem(...)` → `client.itemRemove(...)` (revokes the access token with Plaid)
 - Deletes the `plaid_items` document and all associated `plaid_accounts`, `plaid_transactions`, `plaid_holdings`, `plaid_liabilities` rows for that item.
 - Logs a disconnection event in `sync_logs`.

To withdraw consent for the entire account (all institutions, all data), the user emails matt@tangiblevalue.com per PRIVACY_POLICY.md §7. The deletion SLA is documented in DATA_RETENTION.md.

6. Plaid's own consent layer

When the application launches Plaid Link, Plaid itself surfaces consent screens to the user describing the products being requested (Transactions, Investments, Liabilities, etc.) and the institution being connected. Plaid logs that consent on its side and is responsible for the end-user disclosure of Plaid's own role. This application's consent event is in addition to — not instead of — Plaid's.

7. Auditing the log

To answer "did this user consent?" for a specific user:

```
# Pseudo-query: in Firebase Console → Firestore → consents collection
where user_id == "<id>"
order by consented_at desc
```

Each row will include the timestamp, the policy version that was current at that moment, and the SHA-256 of the consent text. The text itself is in this file under §3 (and in version control for older versions).

8. References

- `PRIVACY_POLICY.md` — what was disclosed at the time of consent
- `DATA_RETENTION.md` — how the consented-to data is retained and deleted
- `src/components/PlaidLink.tsx` — UI that captures the affirmative action
- `backend/routes/plaid.js` → `POST /consent` — server-side endpoint that writes the audit row